
ISO/IEC 17021-1:2015

Plain-Language Guide for the Certified Organization

What your certification body must do, and what that means for you

What each requirement means, why it exists, what it means for you, what to have ready, what to record, and how to report it.

Coverage

The eight principles of Clause 4.

Clause 9 in full: the certification process you will actually experience.

Clauses 5 to 8 and 10: structure, resources, and information.

Audience

Management representatives, compliance managers, and anyone who deals with a certification body and wants to know what they are entitled to expect.

Before You Use This Document

This is a companion guide, not a copy of the standard.

ISO/IEC 17021-1:2015 is a copyrighted publication of ISO and IEC. Nothing in this document reproduces the text of the standard. Every requirement here is described in original wording, using the official clause numbering as reference points only. If you need to rely on the exact wording, obtain a licensed copy. Where this guide and the standard appear to differ, the standard governs. One structural note. ISO/IEC 17021-1 is written for certification bodies: they are the ones required to conform to it, and their accreditation body audits them against it. You are not required to comply with this standard. This guide reads it from the other side of the table, translating each requirement into what it means for the organization being certified.

What this guide does

It takes each requirement in ISO/IEC 17021-1:2015 and answers six questions about it, in the same order every time:

1. **What the clause requires.** What your certification body must do, in ordinary language, with no assumed background.
2. **Why it exists.** The failure it prevents, and why the certification body behaves as it does. A great deal of what feels arbitrary during an audit follows directly from one of these.
3. **What this means for you.** The practical consequence for the organization being certified: what to expect, what to prepare, what you are entitled to ask for, and where your own obligations sit.
4. **Evidence to collect.** Named artifacts, on your side of the relationship. Not “documentation” but the actual thing to have on file.
5. **How to document it.** What to record, whether you are running an internal review of your certification arrangements or preparing to challenge something.
6. **Executive summary treatment.** Suggested language where the position is unsatisfactory, written for an audience that does not read clause numbers.

On vocabulary

Technical terms are defined the first time they appear, shown like [this](#), and collected in the glossary. If you hit a term that is not defined, that is a defect in this document; note it and it will be fixed in the next revision.

Navigating this document

Each part opens with a quick-reference table. Every reference number and title in those tables is a live link to the full entry, so the tables work as a jump menu rather than just a contents list. Entries also appear in the PDF bookmark panel, and the index at the back links back into the text.

Link colour carries meaning. Here it marks whether a clause is something you can *act on*:

Orange, marked cvs

Actionable from your side: a right you can exercise, an obligation on the certification body you can hold it to, or an obligation on *you* that you can breach. This is where to look when something goes wrong, or when you want to know what you are entitled to.

Blue

Internal certification body governance. Real, and assessed by the accreditation body, but not something you interact with directly. Context that makes the rest legible.

Twenty-six of the thirty-one entries are orange, which is itself worth noticing. Read from the certification body's side this standard looks like internal governance. Read from yours, almost every clause creates either something you can ask for or something you can get wrong.

The marker letters are printed as well as coloured, so the distinction survives greyscale printing and does not depend on colour vision. The classification is a judgment, not something the standard states; it is held in a single file in the source and can be re-scoped without touching any content.

One entry, one page

Every clause and control begins at the top of a fresh page and is complete before the next one starts. This wastes some paper and makes the document longer than it needs to be. It also means you can print a single control and hand it to the person who owns it, which is what these documents actually get used for.

How this guide is organized

The first chapter covers the eight principles of Clause 4. They are not auditable requirements in the way the later clauses are; they are the reasoning the rest of the standard expresses, and reading them first makes everything that follows legible.

The second chapter covers Clause 9, the certification process. This is the chapter you will actually experience, from application through audit, findings, the certification decision, surveillance, recertification, and the appeals route. It is the longest chapter and the one to read before your first commercial conversation with a certification body.

The third covers Clauses 5 to 8 and Clause 10: how your certification body is structured and resourced, what it must tell you, and what you must tell it.

Five things that catch people out

Your auditor will not tell you how to fix it. This is impartiality, not unhelpfulness. An auditor who designs your solution is auditing their own work next visit, which destroys the value of the certificate for everyone relying on it. You *may* ask what a requirement means and what evidence would demonstrate conformity. That is explanation, and it is legitimate.

Audit time is not a commercial variable. It follows from complexity and risk, the certification body must record its justification, and accreditation bodies check it. A body that systematically under-audits loses its accreditation. Knowing this saves a negotiation that cannot succeed and redirects it toward what genuinely is adjustable.

Cl. 8.5 is the obligation you are most likely to be breaching right now. You must notify your certification body without delay of changes to ownership, organization and management, sites, scope of operations, and major process change. Acquisitions and new sites do not feel like certification events at the time, which is exactly why this gets missed. Put a notification trigger in your change process.

Read your certificate scope word for word. It is the operative text, it is what customers read, and anything outside it is not certified. Comparing it against what your contracts require takes five minutes and the mismatch is common. It usually surfaces during a tender rather than at a convenient moment.

Using the appeals route is safe. The standard prohibits discriminatory action against anyone who raises an appeal or complaint, and requires that the decision be made by people not involved in the matter. Fear of consequences is what stops most organizations challenging findings they believe are wrong. There is a route, the body is required to operate it, and using it is not an act of hostility.

Three definitions you need before anything else

Impartiality

Actual and perceived objectivity. The word doing the work is *perceived*: a certification body must not only be impartial but be seen to be, and this is why relationships that look compromising are constrained even where no actual bias exists. It is the principle behind most of what organizations find frustrating about how certification bodies behave.

Correction and corrective action

Two different things, and confusing them is the most common reason a nonconformity response is rejected. A *correction* fixes the instance found. A *corrective action* eliminates the cause so it does not recur. The standard requires both, and a response that only supplies the first will come back to you.

Accreditation

Third-party attestation that your certification body is itself competent, assessed against this standard by an accreditation body. This is what makes ISO/IEC 17021-1 enforceable rather than aspirational, and it is why an accredited certificate carries weight that an unaccredited one does not. If you take one action after reading this guide, confirm your certification body's accreditation covers your sector.

How to read the executive summary sections

Every entry ends with suggested reporting language. It is deliberately written to avoid three habits that get security findings ignored: control numbers in the first sentence, adjectives about maturity, and recommendations that amount to "do it better." Each one names a specific consequence and, where possible, attaches a number. Adapt the wording; keep the structure.

Contents

Before You Use This Document	ii
1 The Principles: Clause 4	1
Cl. 4.1 Why the principles matter to you	2
Cl. 4.2 Impartiality: what your certification body cannot do for you	3
Cl. 4.3 Competence: what you can expect of your audit team	4
Cl. 4.4 Responsibility: who is accountable for conformity	5
Cl. 4.5 Openness: what must be public and what you can ask for	6
Cl. 4.6 Confidentiality: what your certification body must protect	7
Cl. 4.7 Responsiveness to complaints: your route when something goes wrong	8
Cl. 4.8 Risk-based approach: why your audit looks the way it does	9
2 The Certification Process: Clause 9	10
Cl. 9.1.1-9.1.2 Application and application review	12
Cl. 9.1.3 The audit programme across the certification cycle	13
Cl. 9.1.4 Audit time: how it is determined and why you cannot simply negotiate it	14
Cl. 9.1.5 Multi-site sampling	15
Cl. 9.2 Audit planning, team selection, and your right to object	16
Cl. 9.3.1 Stage 1: what it is actually for	17
Cl. 9.3.2 Stage 2: the audit that decides	18
Cl. 9.4.5 Findings, nonconformities, and how they are classified	19
Cl. 9.4.8-9.4.9 Cause analysis and demonstrating corrective action	20
Cl. 9.5 The certification decision: made by someone who did not audit you	21
Cl. 9.6.2-9.6.3 Surveillance and recertification	22
Cl. 9.6.5 Suspension, withdrawal, and reduction of scope	23
Cl. 9.7-9.8 Appeals and complaints: how to challenge properly	24
3 Structure, Resources, and Information: Clauses 5 to 8 and 10	25
Cl. 5.1 Legal and contractual matters: what your agreement must cover	27
Cl. 5.2 Management of impartiality and the consultancy separation	28
Cl. 5.3 Liability and financing	29
Cl. 6.2 The committee for safeguarding impartiality	30
Cl. 7.1-7.2 Competence of certification body personnel	31
Cl. 7.3-7.5 External auditors, technical experts, and outsourcing	32
Cl. 8.2 Certification documents: what your certificate must say	33
Cl. 8.3 Use of marks and how you may refer to certification	34
Cl. 8.5 Information exchange: what you must tell your certification body	35
Cl. 10 The certification body's own management system	36
Glossary	37

Index of Terms and Concepts**39**

The Principles: Clause 4

The eight principles of Clause 4. They are not auditable requirements in the way the later clauses are; they are the reasoning the rest of the standard expresses, and they are the most useful part to read first. A great deal of what feels arbitrary during a certification audit follows directly from one of them. Why your auditor will not tell you how to fix a finding is impartiality. Why the person who audited you does not decide whether you are certified is impartiality again. Why audit effort concentrates where it does is the risk-based approach. Why you can challenge a decision without fearing the consequences is responsiveness to complaints.

When something a certification body does seems unreasonable, identify which principle it flows from before challenging it. Where a behaviour traces to no principle at all, that is worth questioning.

Quick reference: the eight principles

Navigation: every reference and title below links to its full entry. Links shown in [orange](#) with a **CYB** or **AI** marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are [blue](#).

Ref	Title	Primary evidence
Cl. 4.1	Why the principles matter to you	Your certification body's published statements on impartiality and confidentiality
Cl. 4.2^{CYB}	Impartiality: what your certification body cannot do for you	The certification body's impartiality statement
Cl. 4.3^{CYB}	Competence: what you can expect of your audit team	Audit team composition and stated competence for your sector
Cl. 4.4	Responsibility: who is accountable for conformity	Your internal audit programme and its coverage
Cl. 4.5^{CYB}	Openness: what must be public and what you can ask for	Your certificate and its scope statement
Cl. 4.6^{CYB}	Confidentiality: what your certification body must protect	Confidentiality provisions in your certification agreement
Cl. 4.7^{CYB}	Responsiveness to complaints: your route when something goes wrong	The certification body's published appeals and complaints process
Cl. 4.8^{CYB}	Risk-based approach: why your audit looks the way it does	Audit plans across cycles, for comparison of where effort was directed

Cl. 4.1 Why the principles matter to you

WHAT THE CLAUSE REQUIRES

Clause 4 sets out the principles that underpin every requirement that follows. They are not themselves auditable requirements on the certification body in the way the later clauses are; they are the reasoning the rest of the standard expresses. The principles establish that certification exists to give confidence to the users of certified organizations, and that this confidence depends on the certification body being impartial, competent, responsible, open, and confidential, and on it responding properly when things go wrong.

WHY IT EXISTS

For an organization being certified, the principles are the most useful part of the standard to read first, because they explain why your certification body behaves as it does. A great deal of what feels arbitrary during an audit follows directly from one of these principles: why the auditor will not tell you how to fix a finding, why the person auditing you cannot be the person who consulted for you, why the decision to certify is not made by your audit team.

WHAT THIS MEANS FOR YOU

1. Read the principles before your first certification cycle. They make the certification body's constraints legible rather than arbitrary.
2. When something a certification body does seems unreasonable, identify which principle it flows from before challenging it.
3. Where a certification body's behaviour does not trace to any principle, that is worth questioning.

EVIDENCE TO COLLECT

- Your certification body's published statements on impartiality and confidentiality
- The accreditation status of your certification body

HOW TO DOCUMENT IT

Record which certification body you use and whether it is accredited, and by whom. Accreditation against this standard is the mechanism that makes the rest of it enforceable, and an unaccredited certificate carries far less weight with the customers you are obtaining it for.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization holds a certificate issued by a body that is not accredited against ISO/IEC 17021-1, so the certificate provides substantially less assurance to customers than an accredited certificate and may not satisfy contractual requirements that specify accredited certification.

Cl. 4.2 Impartiality: what your certification body cannot do for you

WHAT THE CLAUSE REQUIRES

The certification body must be impartial and must be seen to be impartial. The standard requires it to identify, analyse, and manage threats to impartiality arising from its own activities, its relationships, and the relationships of its personnel. Structurally, the most significant consequence is that a certification body cannot provide consultancy to an organization it certifies, and cannot certify an organization where the relationship creates an unacceptable threat that cannot be reduced.

WHY IT EXISTS

This is the principle behind the single most common source of friction: your auditor will not tell you how to fix a nonconformity. It can feel unhelpful, particularly when you are paying them and they plainly know the answer. But an auditor who designs your solution is auditing their own work at the next visit, which destroys the value of the certificate for everyone relying on it, including your customers.

WHAT THIS MEANS FOR YOU

1. Do not ask your audit team to design solutions. They will decline, and pressing puts them in a difficult position for no gain.
2. You may ask what the requirement means and what evidence would demonstrate conformity. That is explanation, not consultancy, and it is legitimate.
3. If you have used a consultant, check the certification body has no relationship with them that creates a threat.
4. If you engage the same firm for consultancy and certification, expect it to be refused, and be wary if it is not.

EVIDENCE TO COLLECT

- The certification body's impartiality statement
- Declared relationships between your consultants and your certification body
- Any conflict declarations made by your audit team

HOW TO DOCUMENT IT

Record whether any party has both advised on your management system and participated in certifying it. If a single firm did both, the certificate is exposed, and it is your certificate that is at risk rather than the certification body's reputation alone.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the same firm provided management system consultancy and performed the certification audit, which is prohibited by the impartiality requirements the certification body operates under, placing the validity of the certificate at risk.

Cl. 4.3 Competence: what you can expect of your audit team

WHAT THE CLAUSE REQUIRES

The certification body must have and maintain the competence needed to perform certification activities, covering both the management system discipline and the technical sector in which you operate. Competence requirements apply to auditors, to technical experts, and to the personnel who make certification decisions, and the body must be able to demonstrate that the specific individuals assigned to your audit have the competence your sector requires.

WHY IT EXISTS

Competence is what makes an audit useful rather than merely procedural. An auditor who understands the standard but not your industry will audit the paperwork and miss the risks, which produces a comfortable audit and a worthless certificate. You are entitled to a team competent in your technical area, and this is a legitimate thing to ask about before an audit rather than to discover during one.

WHAT THIS MEANS FOR YOU

1. Ask about the technical competence of your assigned audit team for your sector before the audit, not after.
2. You may object to a proposed team member on reasonable grounds, including lack of relevant sector competence.
3. Expect a technical expert to accompany the team where your sector requires knowledge the auditors lack.
4. An audit team that cannot engage with your actual technical risks is not delivering the value of certification.

EVIDENCE TO COLLECT

- Audit team composition and stated competence for your sector
- Technical expert involvement where applicable
- Your record of any objection raised and how it was resolved

HOW TO DOCUMENT IT

Record whether the audit team demonstrated sector competence in practice, and whether findings engaged with your real operational risks or only with documentation. A pattern of documentation-only findings across cycles suggests a competence mismatch worth raising.

EXECUTIVE SUMMARY TREATMENT

Suggested language: audit findings across successive cycles have addressed documentation control almost exclusively, with no engagement with the organization's principal operational risks, which suggests the audit team lacks the sector competence needed to deliver assurance from the certification.

Cl. 4.4 Responsibility: who is accountable for conformity

WHAT THE CLAUSE REQUIRES

The organization being certified is responsible for conforming to the requirements of the management system standard. The certification body is responsible for assessing sufficient objective evidence to base a certification decision on, and is not responsible for the organization's conformity. Certification is evidence-based sampling, not a guarantee.

WHY IT EXISTS

This division of responsibility is frequently misunderstood in both directions. Organizations sometimes treat certification as transferring risk to the certification body, which it does not: if your system fails, that is your failure regardless of who certified it. Equally, an audit that finds nothing does not mean nothing is wrong, because auditors sample. A clean report is evidence, not proof.

WHAT THIS MEANS FOR YOU

1. Do not treat a certificate as assurance that your system works. It is evidence that a sample met requirements on the days examined.
2. Maintain your own internal audit and management review as the primary assurance, with certification as external confirmation.
3. Where an audit finds nothing in an area you know is weak, treat that as a sampling outcome rather than a clean bill of health.
4. Remember that responsibility for conformity stays with you between audits, which is most of the time.

EVIDENCE TO COLLECT

- Your internal audit programme and its coverage
- Management review records
- Certification audit reports and their stated scope of sampling

HOW TO DOCUMENT IT

Record whether internal assurance is genuinely independent of the certification cycle. An organization whose only real assurance activity happens in the weeks before an external audit has outsourced its assurance to a sampling exercise.

EXECUTIVE SUMMARY TREATMENT

Suggested language: internal audit activity occurs only in the period immediately preceding external certification audits, so the organization relies on third-party sampling for assurance it is itself responsible for maintaining throughout the year.

Cl. 4.5 Openness: what must be public and what you can ask for

WHAT THE CLAUSE REQUIRES

The certification body must provide appropriate public access to, or disclosure of, information about its audit and certification processes and about the certification status of the organizations it certifies. Openness is qualified by confidentiality: the body discloses that an organization is certified and the scope of that certification, without disclosing the commercially sensitive information it obtained during auditing.

WHY IT EXISTS

Openness is what makes a certificate meaningful to the people relying on it. A customer needs to be able to verify that your certificate is real, current, and covers what you say it covers. The corollary matters to you: the scope statement on your certificate is public-facing and will be read by customers, so it needs to describe accurately what is certified.

WHAT THIS MEANS FOR YOU

1. Check what your certification body publishes about your certification, and confirm the scope statement is accurate.
2. Verify that customers can independently confirm your certificate through the certification body or accreditation body.
3. Ensure your own marketing does not claim broader scope than the certificate states.
4. Ask for the body's published information on its processes if you need to understand how decisions about you are made.

EVIDENCE TO COLLECT

- Your certificate and its scope statement
- The certification body's public register entry for your organization
- Your marketing claims about certification, for comparison

HOW TO DOCUMENT IT

Compare your published claims about certification against the actual certificate scope. Claiming broader coverage than the certificate supports is a misrepresentation to customers and is one of the more common reasons a certification body takes action against a client.

EXECUTIVE SUMMARY TREATMENT

Suggested language: marketing materials describe the organization as certified without qualification, while the certificate covers a single site and a subset of activities, so customers are being given a materially broader impression than the certificate supports.

Cl. 4.6 Confidentiality: what your certification body must protect

WHAT THE CLAUSE REQUIRES

The certification body must have enforceable arrangements to keep confidential the information it obtains or creates during certification activities, and must inform you in advance of information it intends to place in the public domain. Where it is required by law or authorised by contractual arrangement to release confidential information, it must notify you of what it has provided unless prohibited from doing so.

WHY IT EXISTS

Certification requires you to expose a great deal: procedures, records, incidents, findings, sometimes commercially sensitive detail about how you operate. Confidentiality is what makes that exposure tolerable. The notification requirement is the part worth knowing about, because it means disclosure should not happen silently.

WHAT THIS MEANS FOR YOU

1. Confirm confidentiality arrangements are contractual and cover the certification body's personnel, contractors, and any external auditors.
2. Understand what the body will publish about you, since it must tell you in advance.
3. Where information is disclosed under legal compulsion, expect to be told unless the law forbids it.
4. Consider what you expose during an audit, since confidentiality obligations protect it but do not un-disclose it.

EVIDENCE TO COLLECT

- Confidentiality provisions in your certification agreement
- Advance notice of anything to be made public
- Records of any compelled disclosure and notification to you

HOW TO DOCUMENT IT

Record whether the confidentiality arrangements extend to individual external auditors and technical experts, not only to the certification body as an entity. External personnel are common and the obligation must reach them.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the certification agreement binds the certification body but does not demonstrably extend confidentiality obligations to the individual external auditors and technical experts who attend audits and access sensitive operational information.

Cl. 4.7 Responsiveness to complaints: your route when something goes wrong

WHAT THE CLAUSE REQUIRES

The certification body must respond properly to complaints. This principle covers complaints from any party, including complaints made to the certification body about an organization it has certified, and complaints made by a certified organization about the certification body itself. Effective handling of complaints is described as an important means of protection against error, omission, and unreasonable behaviour.

WHY IT EXISTS

This is the principle behind the appeals and complaints machinery in Clause 9, and it is worth knowing exists before you need it. Organizations frequently accept certification body decisions they believe are wrong because they assume there is no route to challenge, or because they fear the relationship consequences. There is a route, the body is required to operate it, and using it is not an act of hostility.

WHAT THIS MEANS FOR YOU

1. Find out how to make a complaint or lodge an appeal before you need to, and who handles it.
2. Distinguish an appeal, which challenges a certification decision, from a complaint, which concerns conduct or service.
3. Understand that the people handling your appeal must not be the people who made the decision being appealed.
4. Do not accept a finding you believe is genuinely wrong simply to preserve the relationship.

EVIDENCE TO COLLECT

- The certification body's published appeals and complaints process
- Records of any appeal or complaint you have raised and its outcome

HOW TO DOCUMENT IT

Record whether the organization has ever challenged a finding it believed to be incorrect. A history of accepting every finding without question, in an organization that disagrees with some of them privately, indicates the appeal route is not functioning as intended.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization has accepted findings it internally assessed as incorrect rather than using the appeal process available to it, so certification outcomes have not been tested where the organization believed they were wrong.

Cl. 4.8 Risk-based approach: why your audit looks the way it does

WHAT THE CLAUSE REQUIRES

The certification body must consider the risk that certification creates for the confidence of the users of certified organizations, and must take that risk into account in how it conducts certification. The standard directs that this risk-based thinking is applied across planning, audit time, sampling, and the attention given to different parts of a management system.

WHY IT EXISTS

This principle explains why two organizations holding the same certificate can have very different audit experiences. Audit effort is meant to follow risk: the complexity of your operations, the consequences of your system failing, your history, and the sector you operate in all legitimately affect how much attention you receive. An audit that looks identical regardless of what the organization does is not applying this principle.

WHAT THIS MEANS FOR YOU

1. Expect audit attention to concentrate where the consequences of failure are greatest, not to distribute evenly.
2. Where you have had a significant incident or a prior nonconformity, expect that area to receive more attention.
3. If audit effort seems disconnected from where your real risks sit, raise it, since the standard supports your position.
4. Understand that risk-based planning is also why audit time is not simply a function of headcount.

EVIDENCE TO COLLECT

- Audit plans across cycles, for comparison of where effort was directed
- Your own risk assessment, for comparison against where the auditor looked

HOW TO DOCUMENT IT

Compare where the audit team spent its time against where your own risk assessment places your principal risks. A sustained mismatch is worth raising with the certification body and is a legitimate basis for asking how the audit programme was planned.

EXECUTIVE SUMMARY TREATMENT

Suggested language: audit effort across the certification cycle has concentrated on administrative processes while the organization's own risk assessment identifies operational areas that received minimal attention, indicating the audit programme is not being planned on a risk basis.

CHAPTER 2

The Certification Process: Clause 9

Thirteen entries covering Clause 9, which is the chapter you will actually experience. Almost entirely orange, because nearly every clause here creates either a right you can exercise or an obligation you can breach.

Read Cl. 9.1.4 on audit time before your first commercial conversation. Audit time is not a variable the certification body can trade away, because its accreditation body checks it, and a body that systematically under-audits loses accreditation. Knowing this saves a negotiation that cannot succeed and redirects it toward what is genuinely adjustable.

Three clauses repay attention before you need them. Cl. 9.4.5 governs how nonconformities are classified, and classification is often more productive to challenge than the finding itself. Cl. 9.4.8 is where most organizations lose credibility, by confusing correction with corrective action: fixing the instance is a correction, preventing recurrence is what the standard requires. And Cl. 9.7-9.8 is the appeals and complaints route, which prohibits discriminatory action against anyone who uses it – the provision organizations most need to know exists, because fear of consequences is what stops them using it.

Quick reference: Process (Cl. 9)

Navigation: every reference and title below links to its full entry. Links shown in orange with a **cyb** or **ai** marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are blue.

Ref	Title	Primary evidence
Cl. 9.1.1-9.1.2^{cyb}	Application and application review	Your application and the information supplied
Cl. 9.1.3^{cyb}	The audit programme across the certification cycle	The audit programme covering the certification cycle
Cl. 9.1.4^{cyb}	Audit time: how it is determined and why you cannot simply negotiate it	Audit time determination and any recorded justification for adjustment
Cl. 9.1.5^{cyb}	Multi-site sampling	Site list and the sampling rationale applied
Cl. 9.2^{cyb}	Audit planning, team selection, and your right to object	Audit plan with objectives, scope, and criteria
Cl. 9.3.1^{cyb}	Stage 1: what it is actually for	Stage 1 report and its readiness conclusion
Cl. 9.3.2^{cyb}	Stage 2: the audit that decides	Performance data against objectives
Cl. 9.4.5^{cyb}	Findings, nonconformities, and how they are classified	Findings with cited requirements and evidence
Cl. 9.4.8-9.4.9^{cyb}	Cause analysis and demonstrating corrective action	Cause analysis for each nonconformity
Cl. 9.5^{cyb}	The certification decision: made by someone who did not audit you	Certification decision record
Cl. 9.6.2-9.6.3^{cyb}	Surveillance and recertification	Certification decision date and surveillance schedule
Cl. 9.6.5^{cyb}	Suspension, withdrawal, and reduction of scope	The certification body's suspension and withdrawal procedure

Ref	Title	Primary evidence
Cl. 9.7-9.8 cvs	Appeals and complaints: how to challenge properly	The published appeals and complaints process

Cl. 9.1.1-9.1.2 Application and application review

WHAT THE CLAUSE REQUIRES

Before certification can proceed, the certification body must obtain the information it needs about your organization and review it. That information covers the scope you are seeking, your locations, the processes and activities involved, your personnel numbers, any outsourced processes, and the management system standard concerned. The review must establish that the body has the competence and capability to perform the certification, that the requirements are defined and understood, and that any differences of understanding between you and the body are resolved before work begins.

WHY IT EXISTS

The application review is where the shape of your entire certification is set: scope, audit time, team composition, and cost all flow from the information you supply here. Understating complexity to reduce cost is a false economy, because the body will discover it later and adjust, usually at a worse moment. Overstating it produces an audit programme larger than you need.

WHAT THIS MEANS FOR YOU

1. Supply accurate information about locations, personnel, shift patterns, and outsourced processes at application.
2. Be explicit about what you want in scope and what you want excluded, and expect to justify exclusions.
3. Resolve any difference in understanding about scope before signing, since it becomes much harder afterwards.
4. Expect the body to decline if it lacks competence in your sector, which is a legitimate outcome rather than a rejection.

EVIDENCE TO COLLECT

- Your application and the information supplied
- The agreed scope statement
- Records of any scope questions resolved before contract

HOW TO DOCUMENT IT

Record whether the scope agreed at application matches what your customers actually need certified. A scope drawn for convenience or cost rather than for the assurance customers require produces a certificate that does not do the job you bought it for.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the certified scope excludes activities that customer contracts require to be covered, so the certificate does not satisfy the contractual obligations it was obtained to meet.

Cl. 9.1.3 The audit programme across the certification cycle

WHAT THE CLAUSE REQUIRES

The certification body must develop an audit programme covering the full certification cycle, identifying the audit activity needed to demonstrate that your management system meets the requirements. The programme covers initial certification, surveillance in the first and second years, and recertification before the certificate expires, and must be reviewed and adjusted where your organization or its context changes significantly.

WHY IT EXISTS

The programme is a cycle rather than a series of events, and it is designed so that the whole of your management system is covered over the cycle rather than every part being examined every time. That is why an area untouched at surveillance is not an area cleared, and why recertification is more demanding than surveillance: it has to conclude on the whole system, not a sample of it.

WHAT THIS MEANS FOR YOU

1. Ask for the programme across the cycle rather than only the next audit plan, so you can anticipate coverage.
2. Tell the certification body about significant change promptly, since the programme is meant to adjust to it.
3. Do not assume an area not examined this year is conforming; it is simply not yet sampled in this cycle.
4. Plan your internal audit coverage to complement, not duplicate, the external programme.

EVIDENCE TO COLLECT

- The audit programme covering the certification cycle
- Notifications of significant change and any resulting programme adjustment

HOW TO DOCUMENT IT

Record whether your internal audit programme covers what the external programme does not, since together they should give complete coverage of the system across the cycle rather than overlapping on the same comfortable areas.

EXECUTIVE SUMMARY TREATMENT

Suggested language: internal and external audit programmes examine substantially the same areas, leaving parts of the management system unexamined by either across the full certification cycle.

Cl. 9.1.4 Audit time: how it is determined and why you cannot simply negotiate it**WHAT THE CLAUSE REQUIRES**

The certification body must determine the time needed to audit your organization, and must have a documented procedure for doing so. The determination accounts for the management system standard concerned, the size and complexity of your organization, its technological and regulatory context, any outsourcing, the number of sites and their nature, the risks associated with your activities, and the results of any prior auditing. The body must record the justification where the time determined departs from the norm.

WHY IT EXISTS

Audit time is the aspect of certification organizations most want to reduce and have least latitude over. It is not a commercial variable the certification body can trade away, because accreditation bodies check it and a body that systematically under-audits loses its accreditation. Understanding this saves a negotiation that cannot succeed, and reframes the conversation toward what actually is adjustable: scheduling, site sampling, and how efficiently the audit is run.

WHAT THIS MEANS FOR YOU

1. Expect audit time to follow from complexity and risk rather than from your budget.
2. Where you believe the time is disproportionate, ask for the justification, which the body must have recorded.
3. Reductions are possible where genuinely justified, such as high automation or repetitive low-risk processes, but must be evidenced.
4. Prepare properly: audit time is fixed, so poor preparation consumes time that would otherwise examine your system.

EVIDENCE TO COLLECT

- Audit time determination and any recorded justification for adjustment
- Your organizational data on which it was based

HOW TO DOCUMENT IT

Record whether the data on which audit time was based is still accurate. Organizations grow, add sites, and change processes without telling the certification body, which means the audit time no longer matches the organization and the certificate is exposed.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization has grown substantially and added locations since its audit time was determined, without notifying the certification body, so the audit programme no longer matches the organization it is intended to cover.

Cl. 9.1.5 Multi-site sampling

WHAT THE CLAUSE REQUIRES

Where certification covers multiple sites, the certification body may sample sites rather than visiting all of them, subject to conditions. Sampling must be justified, must include the central function where one exists, and must be structured so that the sample is representative and varies across the cycle. The standard constrains when sampling is permissible, and certain activities and risk profiles may prevent it.

WHY IT EXISTS

Multi-site sampling is what makes certification affordable for distributed organizations, and it carries an obligation you may not expect: the sites not visited must still conform. A nonconformity found at a sampled site is treated as potentially systemic, because the sample stands for the population. This is why a single site's failure can affect certification across the whole organization.

WHAT THIS MEANS FOR YOU

1. Understand that sampled sites represent the whole, so local failures have organization-wide consequences.
2. Maintain consistency across sites through your own internal audit, since the external sample will not reach most of them.
3. Expect the central function to be audited every time, since it is not sampled out.
4. Do not present your best site repeatedly; the body is required to vary the sample.

EVIDENCE TO COLLECT

- Site list and the sampling rationale applied
- Your internal audit coverage of unsampled sites
- Central function audit records

HOW TO DOCUMENT IT

Record your internal audit coverage of sites the certification body does not visit, since these carry the same conformity obligation and the external programme provides no assurance about them.

EXECUTIVE SUMMARY TREATMENT

Suggested language: sites outside the certification body's sample receive no internal audit either, so the majority of certified locations have never been examined by anyone against the requirements they are certified as meeting.

Cl. 9.2 Audit planning, team selection, and your right to object

WHAT THE CLAUSE REQUIRES

For each audit the certification body must define the objectives, scope, and criteria, select and assign the audit team on the basis of competence, and provide you with an audit plan. Team members must be competent for the assignment, and the body must give you the names of the team in advance with sufficient time for you to object. Where you object on reasonable grounds, the body must address it.

WHY IT EXISTS

The right to object to a proposed team member is a genuine right and is under-used. Legitimate grounds include a conflict of interest, a prior relationship that creates a threat to impartiality, or a lack of competence in your technical area. It is not a mechanism for avoiding an auditor you found demanding, and using it that way will not succeed and will damage the relationship.

WHAT THIS MEANS FOR YOU

1. Review the proposed team in advance and raise reasonable objections promptly rather than at the opening meeting.
2. Review the audit plan and raise conflicts over timing, availability of key personnel, or scope misunderstanding before the audit.
3. Ensure the people the plan requires are actually available; their absence consumes audit time and may cause findings.
4. Check the stated audit criteria match what you expect to be audited against.

EVIDENCE TO COLLECT

- Audit plan with objectives, scope, and criteria
- Team composition notified in advance
- Any objection raised and its resolution

HOW TO DOCUMENT IT

Record whether the audit plan was received with enough time to prepare and to object. Plans arriving too late to act on are a service issue worth raising through the complaints route rather than absorbing.

EXECUTIVE SUMMARY TREATMENT

Suggested language: audit plans are routinely provided too late for the organization to arrange the attendance of key personnel, resulting in findings that reflect availability rather than conformity.

Cl. 9.3.1 Stage 1: what it is actually for

WHAT THE CLAUSE REQUIRES

Initial certification is conducted in two stages. Stage 1 exists to evaluate whether you are ready for stage 2: it examines your management system documentation, assesses your site and site-specific conditions, reviews your understanding of the requirements, gathers information about scope, processes, locations, and statutory and regulatory aspects, confirms resource allocation for stage 2, and provides a focus for planning it. It also evaluates whether your internal audits and management review are being performed.

WHY IT EXISTS

Stage 1 is frequently mistaken for a formality or a friendly pre-visit. It is neither. Its purpose is to determine readiness, and a stage 1 that concludes you are not ready should stop the process rather than proceed to a stage 2 that will fail. Organizations that push through a negative stage 1 usually pay for it twice.

WHAT THIS MEANS FOR YOU

1. Have your internal audits and management review genuinely completed before stage 1, since their absence is a common readiness failure.
2. Treat stage 1 findings as a serious signal about stage 2 readiness rather than as advisory comments.
3. If stage 1 concludes you are not ready, take the delay rather than proceeding, since stage 2 will not go better.
4. Use stage 1 to resolve misunderstandings about scope and criteria while it is still cheap to do so.

EVIDENCE TO COLLECT

- Stage 1 report and its readiness conclusion
- Completed internal audit and management review records
- Actions taken between stage 1 and stage 2

HOW TO DOCUMENT IT

Record whether internal audit and management review were complete and genuine before stage 1, since these two are the most common readiness gaps and both are visible immediately.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization proceeded to stage 2 despite stage 1 identifying that internal audit and management review had not been completed, resulting in nonconformities that were foreseeable and avoidable.

Cl. 9.3.2 Stage 2: the audit that decides

WHAT THE CLAUSE REQUIRES

Stage 2 evaluates the implementation and effectiveness of your management system. It must take place at your site and must cover, among other things, evidence of conformity with all requirements of the applicable standard, performance monitoring and measurement against key objectives and targets, your management system's ability to meet applicable statutory, regulatory, and contractual requirements, your operational control, your internal auditing and management review, and management responsibility for your policies.

WHY IT EXISTS

The word doing the work here is effectiveness. Stage 2 is not a documentation check; it examines whether the system produces the outcomes it is supposed to. An organization with immaculate procedures and no evidence that they change anything will struggle, which is the correct outcome and the reason a certificate means something.

WHAT THIS MEANS FOR YOU

1. Prepare evidence of outcomes, not only of process: performance data, objectives met or missed, and what you did about it.
2. Ensure operational personnel can describe what they do and why, since auditors will ask them rather than only reading procedures.
3. Have evidence that internal audit and management review produced change, since a review that changes nothing is a finding.
4. Expect statutory and regulatory compliance to be examined as part of system effectiveness.

EVIDENCE TO COLLECT

- Performance data against objectives
- Internal audit findings and resulting actions
- Management review outputs and decisions taken
- Evidence of operational control in practice

HOW TO DOCUMENT IT

Record whether the organization can evidence outcomes or only process. Documentation without evidence of effect is the characteristic stage 2 failure and it is visible well in advance.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the management system is fully documented but the organization cannot evidence that it has changed any operational outcome, so effectiveness cannot be demonstrated and certification is at risk.

Cl. 9.4.5 Findings, nonconformities, and how they are classified**WHAT THE CLAUSE REQUIRES**

The certification body must identify and record audit findings, classifying nonconformities and notifying you of them so that you understand and can act on them. Findings are recorded against specific requirements with objective evidence. Where the body raises opportunities for improvement, it must not recommend specific solutions, which follows from the impartiality requirements.

WHY IT EXISTS

The classification of a nonconformity matters commercially, because a major nonconformity normally blocks certification until resolved while a minor does not. Classification turns on whether the failure represents an absence of a required element, a systemic breakdown, or an isolated lapse in a system that otherwise works. If you believe a finding is misclassified, that is a legitimate thing to raise and it is often more productive than disputing the finding itself.

WHAT THIS MEANS FOR YOU

1. Ensure every finding cites the specific requirement and the objective evidence, since you are entitled to both.
2. Where you believe a classification is wrong, raise it at the closing meeting and in writing, before it hardens.
3. Do not expect the auditor to tell you how to fix it; ask instead what evidence would demonstrate conformity.
4. Record findings you disagree with even where you comply, since a pattern is worth appealing.

EVIDENCE TO COLLECT

- Findings with cited requirements and evidence
- Classification of each nonconformity
- Your responses and any classification challenges raised

HOW TO DOCUMENT IT

Record whether findings consistently cite objective evidence. A finding that rests on auditor opinion rather than evidence is challengeable, and organizations frequently accept such findings without realising this.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of recorded nonconformities cite no objective evidence and rest on auditor opinion, and the organization accepted them without challenge, so corrective action has been directed at findings that may not be substantiated.

Cl. 9.4.8-9.4.9 Cause analysis and demonstrating corrective action**WHAT THE CLAUSE REQUIRES**

You are required to analyse the cause of a nonconformity and to describe the specific corrections and corrective actions taken or planned, within a defined time. The certification body must review what you submit and determine whether it is acceptable, and must verify the effectiveness of the actions taken. The body must record how it verified effectiveness, and further evidence or a further audit may be needed.

WHY IT EXISTS

This is where most organizations lose credibility with their certification body. A response that corrects the instance without addressing why it happened will be rejected, because correction and corrective action are different things: fixing the record is a correction, preventing recurrence is corrective action. The standard requires the latter and auditors are trained to spot the difference immediately.

WHAT THIS MEANS FOR YOU

1. Distinguish correction from corrective action explicitly in your response, and provide both.
2. Perform genuine cause analysis; a stated cause of human error will be rejected as insufficient.
3. Submit within the time given, since missing the deadline can escalate the consequence beyond the original finding.
4. Provide evidence the action worked, not only that it was taken, since effectiveness must be verified.

EVIDENCE TO COLLECT

- Cause analysis for each nonconformity
- Correction and corrective action with dates
- Evidence of effectiveness for verification

HOW TO DOCUMENT IT

Record whether cause analysis identifies a systemic cause or restates the finding. Responses that describe what was fixed without explaining why it occurred are the most common reason corrective action is rejected and the audit reopened.

EXECUTIVE SUMMARY TREATMENT

Suggested language: corrective action responses address the individual instances found without identifying systemic cause, so the same nonconformities have recurred across successive audit cycles.

Cl. 9.5 The certification decision: made by someone who did not audit you**WHAT THE CLAUSE REQUIRES**

The certification body makes the certification decision on the basis of the audit information and any other relevant information. The persons or committee making the decision must not have participated in the audit. The body must confirm before deciding that the information is sufficient, that any major nonconformities have been reviewed, accepted, and verified, and that corrective action for minor nonconformities has been reviewed and accepted or a plan agreed.

WHY IT EXISTS

The separation of audit from decision is a structural safeguard, and it has a practical consequence worth anticipating: your audit team does not grant your certificate and cannot promise you one. An auditor saying the audit went well is not a decision, and organizations sometimes act on that assurance before the decision is made. The decision-maker may also reach a different view from the audit team.

WHAT THIS MEANS FOR YOU

1. Do not treat positive signals from the audit team as a certification decision, because it is not theirs to make.
2. Expect a gap between audit completion and decision, and plan customer commitments accordingly.
3. Ensure nonconformity responses are complete before the decision point, since incomplete responses delay it.
4. Understand that the decision-maker may request further information, which is normal rather than adverse.

EVIDENCE TO COLLECT

- Certification decision record
- Evidence that the decision-maker was independent of the audit team
- Nonconformity closure evidence relied upon

HOW TO DOCUMENT IT

Record whether commercial commitments were made on the strength of audit team comments before the formal decision, since this exposes the organization to a gap it does not control.

EXECUTIVE SUMMARY TREATMENT

Suggested language: customer commitments were made on the basis of informal assurance from the audit team before the independent certification decision was taken, exposing the organization to obligations it could not guarantee meeting.

Cl. 9.6.2-9.6.3 Surveillance and recertification

WHAT THE CLAUSE REQUIRES

The certification body must conduct surveillance audits at least once a calendar year, with the first following initial certification within a defined period, and must design surveillance so that representative areas and functions are monitored, taking account of change. Recertification must be planned and conducted to evaluate continued fulfilment of all requirements and the continued effectiveness of the whole management system, and must be completed before the certificate expires.

WHY IT EXISTS

Two timing traps recur. The first surveillance has a deadline tied to the initial certification decision, not to your convenience, and missing it puts the certificate at risk. Recertification must be complete before expiry, which means starting early enough to resolve any nonconformity found, and organizations that book recertification close to the expiry date leave themselves no margin.

WHAT THIS MEANS FOR YOU

1. Diarise the first surveillance deadline from the certification decision date, since it is the tightest constraint in the cycle.
2. Book recertification early enough to resolve nonconformities before expiry, not merely to hold the audit before it.
3. Notify significant change, since surveillance is meant to take account of it.
4. Expect recertification to be broader than surveillance, because it concludes on the whole system.

EVIDENCE TO COLLECT

- Certification decision date and surveillance schedule
- Recertification date against certificate expiry
- Change notifications made to the certification body

HOW TO DOCUMENT IT

Record the interval between the planned recertification audit and certificate expiry. An interval too short to resolve a major nonconformity means the organization is relying on a clean audit, which is not a plan.

EXECUTIVE SUMMARY TREATMENT

Suggested language: recertification is scheduled with insufficient margin before certificate expiry to resolve any major nonconformity, so continuity of certification depends on an audit outcome the organization cannot control.

Cl. 9.6.5 Suspension, withdrawal, and reduction of scope**WHAT THE CLAUSE REQUIRES**

The certification body must have a policy and documented procedure for suspending, withdrawing, or reducing the scope of certification, and must specify the subsequent actions it takes. Suspension applies in defined circumstances, including persistent or serious failure to meet requirements, refusal to allow surveillance or recertification at the required frequency, and a voluntary request. During suspension the certification is temporarily invalid, and the body must make the suspended status publicly accessible and must not permit you to continue promoting the certification.

WHY IT EXISTS

Suspension is the consequence organizations least anticipate and it has immediate commercial effect: the certificate is publicly shown as suspended, and continuing to claim certification during suspension is a misrepresentation. The trigger that surprises people most is refusing or failing to accommodate a required audit, which is treated as seriously as a substantive failure.

WHAT THIS MEANS FOR YOU

1. Accommodate scheduled surveillance and recertification; postponement beyond the permitted frequency is itself a suspension trigger.
2. Where suspension occurs, stop all use of the certification and marks immediately, since continued use is a further breach.
3. Understand what you must do to lift a suspension and the deadline, since failure to resolve leads to withdrawal.
4. Consider the contractual consequences of publicly visible suspension for customers relying on the certificate.

EVIDENCE TO COLLECT

- The certification body's suspension and withdrawal procedure
- Any suspension notice and the conditions for lifting it
- Your controls over use of marks and claims

HOW TO DOCUMENT IT

Record whether the organization has a process to withdraw certification claims quickly across marketing, tender documents, and customer communications, since suspension requires this immediately and few organizations can do it fast.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization has no mechanism to withdraw certification claims from marketing, proposals, and customer materials at short notice, so a suspension would result in continued misrepresentation of certified status.

Cl. 9.7-9.8 Appeals and complaints: how to challenge properly**WHAT THE CLAUSE REQUIRES**

The certification body must have a documented process to receive, evaluate, and decide on appeals and complaints, and must make it publicly accessible. The process must ensure that decisions on appeals and complaints are made by, or reviewed and approved by, persons not involved in the matter in question, and that submitting one does not result in any discriminatory action. The body must acknowledge, investigate, and formally notify the outcome.

WHY IT EXISTS

An appeal challenges a certification decision; a complaint concerns the body's conduct or service. Both are protected: the standard prohibits discriminatory action against a party that raises one, which is the provision organizations most need to know about, because the fear of consequences is what stops most of them using the route. The requirement for independent decision-making is what makes the process meaningful rather than an internal rubber stamp.

WHAT THIS MEANS FOR YOU

1. Use the correct route: appeal a decision, complain about conduct, since misdirecting it delays resolution.
2. Put it in writing with the specific decision or conduct, the grounds, and the outcome sought.
3. Expect the matter to be decided by someone not involved in it, and ask if that is unclear.
4. Escalate to the accreditation body if the certification body's own process does not resolve it properly.

EVIDENCE TO COLLECT

- The published appeals and complaints process
- Your submission and the body's acknowledgement and outcome
- Evidence of independent decision-making where relevant

HOW TO DOCUMENT IT

Record whether the organization knows how to escalate beyond the certification body to the accreditation body. This is the ultimate route where a certification body handles a matter improperly, and most certified organizations are unaware it exists.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization is unaware of the escalation route to the accreditation body and has accepted certification body decisions it believes were improperly handled, leaving legitimate grievances unresolved.

CHAPTER 3

Structure, Resources, and Information: Clauses 5 to 8 and 10

Eleven entries covering the requirements that shape how your certification body is built and what it must tell you. Mixed colouring: several of these clauses are internal governance you will never touch, while others carry the obligations you are most likely to breach.

Cl. 8.5 is the one to act on first. It requires you to notify your certification body without delay of changes to ownership, organization and management, sites, scope of operations, and major process change. This is the obligation certified organizations breach most often, almost always without realising, because acquisitions and new sites do not feel like certification events at the time. Put a notification trigger in your change process.

Cl. 8.3 on marks is the second. Applying a certification mark in a way that implies product certification, or continuing to display it after suspension, are both breaches with real consequences including publication of the transgression. Audit your own mark usage across vehicle livery, packaging, and partner websites, not just the channels marketing controls.

Cl. 8.2 takes five minutes and is worth doing today: read your certificate scope statement word for word against what your contracts require. Mismatches are common and usually surface during a tender rather than at a convenient moment.

Quick reference: Structure (Cl. 5-8, 10)

Navigation: every reference and title below links to its full entry. Links shown in **orange** with a **cyb** or **ai** marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are **blue**.

Ref	Title	Primary evidence
Cl. 5.1^{cyb}	Legal and contractual matters: what your agreement must cover	The certification agreement and its obligations on you
Cl. 5.2^{cyb}	Management of impartiality and the consultancy separation	Your consultancy and internal audit supplier relationships
Cl. 5.3	Liability and financing	Certification body accreditation status and standing
Cl. 6.2	The committee for safeguarding impartiality	The certification body's published governance information
Cl. 7.1-7.2^{cyb}	Competence of certification body personnel	The body's stated competence and accreditation scope for your sector
Cl. 7.3-7.5^{cyb}	External auditors, technical experts, and outsourcing	Confidentiality coverage for external personnel
Cl. 8.2^{cyb}	Certification documents: what your certificate must say	Your current certificate with scope, sites, and dates
Cl. 8.3^{cyb}	Use of marks and how you may refer to certification	Your mark usage across all channels

Ref	Title	Primary evidence
Cl. 8.5 cvb	Information exchange: what you must tell your certification body	Notifications made to the certification body with dates
Cl. 10	The certification body's own management system	Certification body accreditation certificate and scope

Cl. 5.1 Legal and contractual matters: what your agreement must cover

WHAT THE CLAUSE REQUIRES

The certification body must be a legal entity, or a defined part of one, so that it can be held legally responsible for its certification activities. It must have a legally enforceable agreement with each organization it certifies, and that agreement must require the organization to comply with the certification requirements, including making arrangements for the conduct of audits, providing access to information and records, and giving access for witness auditing by the accreditation body.

WHY IT EXISTS

The agreement is the instrument that binds you as well as the certification body, and the obligations it places on you are easy to overlook at signature and awkward to discover later. Two catch organizations out: the obligation to accommodate audits at the required frequency, and the obligation to permit accreditation body witness audits, where an assessor attends to observe your auditor working.

WHAT THIS MEANS FOR YOU

1. Read what the agreement obliges you to do, not only what it obliges the certification body to do.
2. Note the witness audit obligation: you may be asked to host an accreditation assessor observing your audit.
3. Check notification obligations, since these are usually in the agreement rather than in the standard you are certified against.
4. Confirm the certification body is a legal entity capable of being held responsible.

EVIDENCE TO COLLECT

- The certification agreement and its obligations on you
- Notification obligations and their triggers
- Records of any witness audit hosted

HOW TO DOCUMENT IT

Record whether the organization has read and can meet its own obligations under the agreement, particularly notification. Breach of the agreement is a route to suspension independent of any failure in your management system.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization has not met the notification obligations in its certification agreement, which is a breach independent of management system conformity and a route to suspension.

Cl. 5.2 Management of impartiality and the consultancy separation

WHAT THE CLAUSE REQUIRES

The certification body's top management must be committed to impartiality, and the body must have a publicly accessible statement to that effect. It must identify, analyse, and document threats to impartiality on an ongoing basis, including those arising from its relationships and from the relationships of its personnel, and eliminate or minimise them. The standard constrains relationships involving management system consultancy and internal auditing for organizations the body certifies, and sets time constraints on personnel moving between such work and auditing.

WHY IT EXISTS

The time constraints are the practical part for you. If an individual consulted for you or performed your internal audits, there is a period during which that person cannot audit you for certification. The same applies to the body itself where it provided such services. Organizations that use a single supplier for everything discover this at the worst point, when the audit is booked.

WHAT THIS MEANS FOR YOU

1. Disclose consultancy and internal audit relationships to the certification body rather than waiting for it to ask.
2. Where an individual has consulted for you, expect them to be excluded from your audit team for a period.
3. Be cautious of any provider offering both consultancy and accredited certification for the same system.
4. Understand that using a related entity of your certification body for consultancy may also create a threat.

EVIDENCE TO COLLECT

- Your consultancy and internal audit supplier relationships
- Disclosures made to the certification body
- The body's impartiality statement

HOW TO DOCUMENT IT

Record any overlap between advisers and certifiers, including at the level of individual people and of related corporate entities. This is the exposure that most often invalidates a certificate after the fact.

EXECUTIVE SUMMARY TREATMENT

Suggested language: individuals who designed the organization's management system subsequently participated in its certification audit within the constrained period, creating an impartiality threat that places the certificate at risk.

Cl. 5.3 Liability and financing

WHAT THE CLAUSE REQUIRES

The certification body must have adequate arrangements to cover liabilities arising from its operations, and must evaluate its finances and sources of income and demonstrate to the accreditation body that no commercial, financial, or other pressure compromises its impartiality. This addresses the risk that financial dependence on a single client or a concentrated client base influences certification decisions.

WHY IT EXISTS

The financial independence requirement exists because a certification body that cannot afford to lose you cannot credibly certify you. For an organization choosing a certification body, this is worth considering in the opposite direction: a body for which you would be a disproportionately large client faces a pressure the standard is designed to prevent, and that is not in your interest either, because the certificate is worth less.

WHAT THIS MEANS FOR YOU

1. Consider whether you would represent a disproportionate share of a small certification body's income.
2. Verify the body carries liability arrangements appropriate to the work.
3. Treat unusually aggressive pricing with some caution, since audit time is not a commercial variable.
4. Assess continuity risk: a body that fails commercially leaves you needing to transfer certification.

EVIDENCE TO COLLECT

- Certification body accreditation status and standing
- Liability arrangements referenced in the agreement

HOW TO DOCUMENT IT

Record the continuity risk of your certification body, since transfer of certification is possible but disruptive and is best considered before it becomes necessary.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization's certification depends on a certification body whose continuity has not been assessed, with no contingency for transfer should that body cease to operate or lose accreditation.

Cl. 6.2 The committee for safeguarding impartiality

WHAT THE CLAUSE REQUIRES

The certification body must have a structure that safeguards its impartiality, including a mechanism involving a balance of interests such that no single interest predominates. This structure must be able to assist on matters affecting confidence in certification, including on policies, on any tendency of the body to allow commercial considerations to prevent objective provision of certification activities, and must be able to take independent action if the body's top management does not respect its advice.

WHY IT EXISTS

This is internal governance and is mostly invisible to you, but it is the mechanism through which systemic problems at a certification body are meant to be caught. It matters indirectly: it is part of why an accredited certificate carries weight, and it is one of the things an accreditation body examines. It is also a route of last resort if you believe a body is behaving commercially rather than impartially at an institutional level.

WHAT THIS MEANS FOR YOU

1. Understand that this structure exists as a safeguard, though you will rarely interact with it directly.
2. Where you believe a certification body is systematically compromised by commercial pressure, this is one of the mechanisms intended to address it.
3. Recognise this as part of what distinguishes accredited from unaccredited certification.

EVIDENCE TO COLLECT

- The certification body's published governance information
- Accreditation status confirming these structures are assessed

HOW TO DOCUMENT IT

Record whether your certification body is accredited, since accreditation is what verifies these governance structures exist and function. An unaccredited body may satisfy none of this.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the certificate was issued by an unaccredited body, so none of the governance structures that make certification credible have been independently verified.

Cl. 7.1-7.2 Competence of certification body personnel

WHAT THE CLAUSE REQUIRES

The certification body must determine the competence criteria for personnel involved in each function of certification activity, covering management system knowledge, sector-specific technical knowledge, and auditing skills. It must have processes to determine, evaluate, and demonstrate the competence of these personnel, and must have access to the necessary technical expertise for advice on matters relating to the sectors it certifies.

WHY IT EXISTS

Competence requirements attach to functions, not just to auditors: the people reviewing your application, planning your audit, and taking the certification decision are all subject to them. For you, the practical consequence is that you are entitled to a team competent in your sector, and that a body without access to expertise in your sector should decline to certify you rather than proceed with a general team.

WHAT THIS MEANS FOR YOU

1. Ask what sector competence the body holds before engaging it, not after.
2. Where your sector is specialised, ask how the body obtains technical expertise for it.
3. Treat a body willing to certify any sector without evident expertise with caution.
4. Recognise that competence applies to the decision-maker as well as the audit team.

EVIDENCE TO COLLECT

- The body's stated competence and accreditation scope for your sector
- Audit team competence for your specific assignment

HOW TO DOCUMENT IT

Check the certification body's accreditation scope covers your sector. Bodies are accredited for defined scopes, and a certificate issued outside the body's accredited scope is not an accredited certificate whatever it says.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the certificate was issued outside the certification body's accredited scope for the organization's sector, so it does not carry accredited status despite being presented as accredited certification.

Cl. 7.3-7.5 External auditors, technical experts, and outsourcing**WHAT THE CLAUSE REQUIRES**

Where the certification body uses individual external auditors or external technical experts, it must have written agreements with them covering confidentiality and independence from commercial and other interests, and must ensure they meet the applicable competence requirements. Where the body outsources work associated with certification, it must have a legally enforceable agreement covering the arrangements including confidentiality and conflicts of interest, and remains responsible for all outsourced work.

WHY IT EXISTS

Much of the audit workforce is contracted rather than employed, which is normal and not a concern in itself. What matters to you is that the obligations reaching the certification body must also reach these individuals, particularly confidentiality. The body remains responsible for outsourced work, so a failure by a contracted auditor is the body's failure and you address it with the body.

WHAT THIS MEANS FOR YOU

1. Confirm confidentiality obligations extend to external auditors and technical experts attending your site.
2. Where an issue arises with a contracted auditor, raise it with the certification body, which remains responsible.
3. Expect external technical experts where your sector requires knowledge the core team lacks.
4. Understand that certification decisions cannot be outsourced.

EVIDENCE TO COLLECT

- Confidentiality coverage for external personnel
- Composition of your audit team including external members

HOW TO DOCUMENT IT

Record whether external audit team members are covered by the same confidentiality obligations as employees. This is a reasonable question to ask and is occasionally answered less confidently than it should be.

EXECUTIVE SUMMARY TREATMENT

Suggested language: external auditors and technical experts attending audits and accessing sensitive operational information are not demonstrably bound by the confidentiality obligations that apply to the certification body's own personnel.

Cl. 8.2 Certification documents: what your certificate must say

WHAT THE CLAUSE REQUIRES

The certification body must provide certification documents to the certified organization by any means it chooses. The documents must identify the certification body, the organization certified and its address, the scope of certification, the effective date of certification, and the management system standard certified against, together with any other information required by the standard concerned. Certification documents must be issued only after, or on, the granting of certification.

WHY IT EXISTS

The scope statement on the certificate is the operative text and the part customers read. It defines what is certified, and anything outside it is not. Organizations routinely hold certificates whose scope wording is narrower than they believe or than their customers assume, and the discovery usually happens during a tender or a customer audit rather than in a calm moment.

WHAT THIS MEANS FOR YOU

1. Read your certificate scope statement as a customer would, and confirm it says what you need it to say.
2. Check locations listed are complete and current, since sites added later are not automatically covered.
3. Verify the standard and edition cited is the one your customers require.
4. Where scope is wrong or has drifted, request a change rather than explaining it away in tenders.

EVIDENCE TO COLLECT

- Your current certificate with scope, sites, and dates
- Customer and contractual requirements for comparison

HOW TO DOCUMENT IT

Compare the certificate scope word for word against what contracts and tenders require. A mismatch is common, discoverable in minutes, and materially consequential.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the certificate scope omits locations and activities that customer contracts require to be certified, so the organization is representing coverage the certificate does not provide.

Cl. 8.3 Use of marks and how you may refer to certification

WHAT THE CLAUSE REQUIRES

The certification body must exercise proper control over ownership, use, and display of its certification marks, and must require that the certified organization does not use its certification in a way that brings the body into disrepute or makes any statement about certification that the body may consider misleading or unauthorised. The body must have arrangements to take action in response to incorrect references to certification status or misleading use of marks, including corrective action, suspension, withdrawal, publication of the transgression, and legal action.

WHY IT EXISTS

This is the clause organizations breach most often and most casually. Common failures include applying a certification mark to a product, which management system certification does not support; implying certification of a site or activity outside scope; and continuing to display marks after suspension or expiry. The consequences listed are real and include publication of the transgression.

WHAT THIS MEANS FOR YOU

1. Confirm you understand the difference between certifying a management system and certifying a product; marks must not imply the latter.
2. Audit your own use of marks across website, proposals, email signatures, packaging, and vehicles.
3. Ensure marks and claims can be withdrawn quickly if certification is suspended or lapses.
4. Check group companies and resellers are not using your marks outside your certified scope.

EVIDENCE TO COLLECT

- Your mark usage across all channels
- Certification body rules on mark use
- Controls over use by group entities and partners

HOW TO DOCUMENT IT

Audit mark usage yourself across every channel, including ones marketing does not control. Vehicle livery, packaging, and partner websites are the usual sites of breach and are rarely reviewed.

EXECUTIVE SUMMARY TREATMENT

Suggested language: certification marks are applied to product packaging in a manner implying product certification, which management system certification does not support and which the certification body may treat as misleading use warranting suspension.

Cl. 8.5 Information exchange: what you must tell your certification body

WHAT THE CLAUSE REQUIRES

The certification body must give certified organizations due notice of changes to its certification requirements and verify that each organization conforms to them. It must also require organizations to inform it, without delay, of matters that may affect the capability of the management system to continue fulfilling requirements, including changes to legal, commercial, organizational status or ownership, organization and management, contact address and sites, scope of operations, and major changes to the management system and processes.

WHY IT EXISTS

This is the obligation certified organizations breach most frequently, usually without realising it. Acquisitions, new sites, senior management changes, and significant process changes all trigger it, and none of them feel like certification events at the time. The certification body cannot maintain a valid certificate for an organization it no longer accurately understands, and undisclosed change is a route to suspension.

WHAT THIS MEANS FOR YOU

1. Establish a trigger in your change and governance processes that prompts notification to the certification body.
2. Notify acquisitions, disposals, new sites, and significant process change without waiting for the next audit.
3. Treat senior management change as notifiable, since the standard names organization and management explicitly.
4. Track changes the certification body notifies to you, since you must conform to changed requirements.

EVIDENCE TO COLLECT

- Notifications made to the certification body with dates
- Your change management process and its notification trigger
- Changes to certification requirements notified to you and your response

HOW TO DOCUMENT IT

Record whether any notifiable change occurred during the period without being notified. Compare notifications against your own change, acquisition, and site records rather than accepting that none occurred.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization acquired a business and opened additional sites during the period without notifying its certification body, breaching its notification obligation and leaving the certificate covering an organization that no longer exists in the form certified.

Cl. 10 The certification body's own management system

WHAT THE CLAUSE REQUIRES

The certification body must establish and maintain a management system capable of supporting and demonstrating the consistent achievement of the requirements of this standard. It may do so either through a general management system meeting specified requirements, or through a management system conforming to ISO 9001 and capable of supporting and demonstrating consistent fulfilment of this standard's requirements.

WHY IT EXISTS

This is entirely internal to the certification body and you will not interact with it, but it completes the logic: the body that audits your management system is required to operate one of its own, and its accreditation body audits that. Understanding this makes the whole structure legible, and it is the answer to the reasonable question of who audits the auditors.

WHAT THIS MEANS FOR YOU

1. Recognise that your certification body is itself audited, by its accreditation body, against this standard.
2. Where the body's own processes fail you repeatedly, the accreditation body is the escalation route.
3. Consider that accreditation body assessment is why witness audits occur at your site.

EVIDENCE TO COLLECT

- Certification body accreditation certificate and scope
- The accreditation body's contact route

HOW TO DOCUMENT IT

Record the accreditation body for your certification body and how to contact it. This is the escalation route of last resort and is worth knowing before it is needed rather than discovering during a dispute.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization does not know which accreditation body oversees its certification body, and therefore has no identified escalation route where the certification body's own process fails to resolve a matter properly.

Glossary

Terms are listed alphabetically. Each is also indexed at the point of first use.

Accreditation

Third-party attestation that a certification body is competent to carry out specific certification tasks. The mechanism that makes ISO/IEC 17021-1 enforceable. An unaccredited certificate carries substantially less weight.

Accreditation body

The body that assesses and accredits certification bodies. Your escalation route of last resort where a certification body's own process fails to resolve a matter.

Appeal

A request to reconsider a certification decision. Distinct from a complaint. Must be decided by people not involved in the original decision, and raising one must not result in discriminatory action.

Audit time

The time determined for auditing your organization, based on size, complexity, risk, and context. Not a commercial variable; accreditation bodies check it.

Certification body

The body that audits and certifies your management system. Abbreviated CB.

Complaint

An expression of dissatisfaction about a certification body's conduct or service, or about a certified organization. Distinct from an appeal.

Consultancy

Participation in designing, implementing, or maintaining a management system. A certification body cannot provide it to an organization it certifies, and time constraints apply to individuals moving between consultancy and auditing.

Correction

Action to eliminate a detected nonconformity itself. Distinct from corrective action, and supplying only this is the most common reason a response is rejected.

Corrective action

Action to eliminate the cause of a nonconformity so it does not recur. What the standard actually requires alongside correction.

Impartiality

Actual and perceived presence of objectivity. The principle behind why your auditor will not design your solutions.

Major nonconformity

A nonconformity affecting the capability of the management system to achieve intended results. Normally

blocks certification until resolved.

Minor nonconformity

A nonconformity that does not affect the capability of the management system to achieve intended results. Normally does not block certification.

Recertification

The audit concluding on continued fulfilment of all requirements and the effectiveness of the whole system. Must be completed before the certificate expires.

Scope of certification

The extent of activities, sites, and processes covered by the certificate. The operative text your customers read; anything outside it is not certified.

Stage 1

The first part of initial certification, evaluating readiness for stage 2. Not a formality.

Stage 2

The audit evaluating implementation and effectiveness of the management system, conducted at your site.

Surveillance

Audits during the certification cycle monitoring representative areas, conducted at least once a calendar year.

Suspension

Temporary invalidation of certification. Publicly visible, and continuing to claim certification during suspension is a further breach.

Technical expert

A person providing specific knowledge or expertise on the subject to be audited. Accompanies the audit team where sector knowledge is required; does not audit independently.

Witness audit

An accreditation body assessor observing your certification audit to assess the certification body. Your agreement generally obliges you to permit it.

Workpaper

The assessor's record of what was tested, how, what was found, and what was concluded.

Index of Terms and Concepts

- Accreditation, 37
- Accreditation body, 37
- Appeal, 37
- Appeals and complaints: how to challenge properly, 24
- Application and application review, 12
- Audit planning, team selection, and your right to object, 16
- Audit time, 37
- Audit time: how it is determined and why you cannot simply negotiate it, 14
- Cause analysis and demonstrating corrective action, 20
- Certification body, 37
- Certification documents: what your certificate must say, 33
- Competence of certification body personnel, 31
- Competence: what you can expect of your audit team, 4
- Complaint, 37
- Confidentiality: what your certification body must protect, 7
- Consultancy, 37
- Correction, 37
- Corrective action, 37
- External auditors, technical experts, and outsourcing, 32
- Findings, nonconformities, and how they are classified, 19
- Impartiality, 37
- Impartiality: what your certification body cannot do for you, 3
- Information exchange: what you must tell your certification body, 35
- Legal and contractual matters: what your agreement must cover, 27
- Liability and financing, 29
- Major nonconformity, 37
- Management of impartiality and the consultancy separation, 28
- Minor nonconformity, 38
- Multi-site sampling, 15
- Openness: what must be public and what you can ask for, 6
- Recertification, 38
- Responsibility: who is accountable for conformity, 5
- Responsiveness to complaints: your route when something goes wrong, 8
- Risk-based approach: why your audit looks the way it does, 9
- Scope of certification, 38
- Stage 1, 38
- Stage 1: what it is actually for, 17
- Stage 2, 38
- Stage 2: the audit that decides, 18
- Surveillance, 38
- Surveillance and recertification, 22
- Suspension, 38
- Suspension, withdrawal, and reduction of scope, 23
- Technical expert, 38
- The audit programme across the certification cycle, 13
- The certification body's own management system, 36
- The certification decision: made by someone who did not audit you, 21
- The committee for safeguarding impartiality, 30
- Use of marks and how you may refer to certification, 34
- Why the principles matter to you, 2
- Witness audit, 38
- Workpaper, 38